System Risk Assessment — Collaboration Suite (Confluence, Jira, Mattermost, Nextcloud)

Larkspur Logistics, Inc. · System Risk Assessment · SRA-2026-03 v2.1

Field	Value
Document id	SRA-2026-03
Version	2.1
Classification	INTERNAL — CONFIDENTIAL (fictitious)
System	Collaboration Suite
Owner team	Workplace Technology
Assessment date	2026-06-12
Next review	2026-12-12
Assessor	Security Operations (SecOps), with Workplace Technology
Exposure	internet-facing
Data classification	Confidential

1. Purpose and scope

This assessment covers the self-hosted collaboration tools used by all 2,400 employees and by selected partners: Confluence and Jira Data Center for documentation and work tracking, Mattermost for chat, and Nextcloud for file exchange with customers and partners. Two of the four applications are reachable from the internet, which is why the suite is treated as an internet-facing system for the purposes of the Vulnerability Management Policy even though most users reach it through the corporate VPN.

2. System overview

Confluence Data Center hosts the company's internal documentation (about 41,000 pages across 380 spaces) and a public space, "Customer Documentation", that is served anonymously to customers through the NetScaler ADC pair of the Customer Portal. Jira Software Data Center tracks engineering, operations and customer-service work and is reachable only through the VPN. Mattermost provides chat, channels and incident playbooks for staff. Nextcloud provides file sharing with external parties through public links and guest accounts, with in-browser document editing provided by the Collabora Online Built-in CODE Server app.

Data classification is Confidential: the suite contains contracts, operational procedures, incident records, HR material in restricted spaces, and customer documents exchanged through Nextcloud. Personal data of employees is present in profiles and HR spaces. Availability tier is Tier 2 (business hours, eight-hour recovery objective).

Staff authenticate through the Keycloak staff realm with MFA (SAML for Mattermost, OIDC for the others). Nextcloud guest accounts for partners use local passwords with mandatory MFA. The Confluence public space is anonymous read-only.

3. Architecture and hosts

Confluence and Jira run as single-node Data Center deployments on dedicated hosts with a shared PostgreSQL server. Confluence is published to the internet through the Customer Portal's NetScaler ADC

pair with a content-switching policy that forwards only the public space's paths and the static resources they need; all other paths require the VPN. Nextcloud runs behind its own NGINX reverse proxy in the DMZ and is reachable from the internet on TCP 443 for public links and guest logins. Mattermost runs on the internal segment and is reachable from the VPN, including the mobile apps.

The applications share an Elasticsearch-free architecture: Confluence and Jira use their bundled search, Mattermost uses its PostgreSQL full-text search. Attachments and Nextcloud files are stored on the NAS volume mounted on each host.

3.1 Host inventory

Hostname	IP address	Zone	Role	Operating system
confluence-01.corp.example	198.51.100.110	Internal (published via DMZ ADC)	Confluence Data Center node	RHEL 9.5
jira-01.corp.example	198.51.100.111	Internal	Jira Software Data Center node	RHEL 9.5
collab-db-01.corp.example	198.51.100.115	Internal	PostgreSQL for Confluence and Jira	RHEL 9.5
chat-01.corp.example	198.51.100.120	Internal	Mattermost server	Ubuntu 24.04 LTS
chat-db-01.corp.example	198.51.100.121	Internal	PostgreSQL for Mattermost	Ubuntu 24.04 LTS
files-proxy-01.dmz.corp.example	203.0.113.40	DMZ	NGINX reverse proxy for Nextcloud	Ubuntu 24.04 LTS
files-01.corp.example	198.51.100.130	Internal	Nextcloud application server	Ubuntu 24.04 LTS
files-db-01.corp.example	198.51.100.131	Internal	PostgreSQL for Nextcloud	Ubuntu 24.04 LTS
bastion-01.mgmt.corp.example	192.0.2.5	Management	SSH bastion (MFA)	Ubuntu 24.04 LTS

4. Software bill of materials

The components below were confirmed from package manifests and running processes during the assessment. Versions are as deployed on the assessment date.

Component	Vendor / project	Version	Role in the system	Deployed on
Confluence Data Center	Atlassian	9.2.21	Internal documentation and the public Customer Documentation space	confluence-01
Jira Software Data Center	Atlassian	10.3.18	Work tracking for engineering, operations and customer service	jira-01
Mattermost	Mattermost Inc.	11.8.3	Team chat, channels, incident playbooks	chat-01
Nextcloud Server	Nextcloud GmbH	31.0.6	File exchange with customers and partners	files-01, files-proxy-01
Collabora Online Built-in CODE Server (richdocumentscode)	Collabora Productivity	26.4.202	In-browser document editing inside Nextcloud	files-01
PostgreSQL	PostgreSQL Global Development Group	16.8	Databases for Confluence, Jira, Mattermost and Nextcloud	collab-db-01, chat-db-01, files-db-01

Component	Vendor / project	Version	Role in the system	Deployed on
NGINX Open Source	F5 / nginx project	1.26.3	Reverse proxy for Nextcloud in the DMZ	files-proxy-01

4.1 Component notes

Confluence Data Center 9.2.21

Confluence Data Center 9.2.21 (long-term support line) with 380 spaces. The public space is the only content reachable without authentication; it is exposed through the Customer Portal's ADC with a content-switching policy, so the internet-facing surface is the Confluence web application itself on the published paths. The instance runs the Atlassian-bundled Tomcat and Java. Upgrades follow the LTS bug-fix releases about every two months, applied by Workplace Technology.

Jira Software Data Center 10.3.18

Jira Software Data Center 10.3.18 (long-term support line), reachable only through the VPN. It holds customer-service tickets that may contain customer personal data. It shares the PostgreSQL server with Confluence and is upgraded on the same cadence.

Mattermost 11.8.3

Mattermost 11.8.3 (Professional) with SAML single sign-on through Keycloak, the Boards and Playbooks features enabled, and invite-only teams for the security and HR functions. The server is reachable from the VPN only, including the mobile applications through the VPN client. The Mattermost Agents plugin is not installed.

Nextcloud Server 31.0.6

Nextcloud Server 31.0.6 (Hub 10) is reachable from the internet through the DMZ reverse proxy for public links and guest logins. Internal users authenticate through Keycloak. Server-side encryption is not enabled; files are on the NAS volume. Apps installed: Files, Sharing, Collabora Online (richdocuments) with the built-in CODE server, Talk disabled.

Collabora Online Built-in CODE Server (richdocumentscode) 26.4.202

The built-in CODE server app (richdocumentscode) 26.4.202 provides document editing without a standalone Collabora deployment. It is started on demand by Nextcloud through the app's proxy.php endpoint, which is reachable on the same internet-facing virtual host as Nextcloud. The app is updated from the Nextcloud app store when Workplace Technology updates Nextcloud.

PostgreSQL 16.8

Three PostgreSQL 16.8 instances on separate hosts, each reachable only from its application host, with TLS and SCRAM authentication.

NGINX Open Source 1.26.3

The Ubuntu-packaged NGINX 1.26.3 terminates TLS for Nextcloud and forwards to files-01. It carries no WAF policy; rate limiting is configured for the login and public-link endpoints.

5. Network exposure

Internet-facing surface: the Confluence public space on the published paths through the ADC (TCP 443), and Nextcloud with the built-in CODE server through the DMZ reverse proxy (TCP 443). Jira and Mattermost are reachable only through the VPN. The ADC's WAF policy covers the Confluence published paths; the Nextcloud proxy has no WAF.

Because the Confluence public space is served by the same web application as the internal spaces, an unauthenticated vulnerability in Confluence is reachable from the internet even though the content-switching policy limits the published paths to the public space. Workplace Technology reviews the published path list with each Confluence upgrade.

5.1 Exposed endpoints

Port / protocol	Service	Reachable from	Authentication
443/tcp	Confluence public space (via Customer Portal ADC)	Internet	Anonymous read-only (published paths only)
443/tcp	Confluence (all spaces)	VPN	Keycloak OIDC (MFA)
443/tcp	Jira Software	VPN	Keycloak OIDC (MFA)
443/tcp	Mattermost web	VPN	Keycloak SAML (MFA)
443/tcp	Nextcloud and built-in CODE server	Internet	Public links; guest accounts (MFA); Keycloak OIDC for staff
5432/tcp	PostgreSQL (three instances)	Respective application host only	SCRAM + TLS
22/tcp	SSH	Management bastion only	Key + MFA at the bastion

6. Security controls

Control	Status	Last verified	Notes
WAF policy on the Confluence published paths (NetScaler AppFW)	In place	2026-06-02	Shares the Customer Portal's ADC pair.
Content switching restricts internet access to the public space's paths	In place	2026-06-02	Path list reviewed at each Confluence upgrade.
SSO with MFA for staff on all four applications	In place	2026-06-02	Guest accounts on Nextcloud use local passwords with MFA.
WAF or rate limiting in front of Nextcloud	Partial	2026-06-02	Rate limiting only; no WAF (F-2026-032).
Weekly authenticated vulnerability scan	In place	2026-06-08	All hosts.
Centralised logging to the SIEM	In place	2026-06-02	Application audit logs and proxy access logs.
Attachment and file malware scanning	In place	2026-05-30	ClamAV on the NAS volume; Nextcloud antivirus app.

7. Open findings

Id	Severity	Finding	Owner	Due
F-2026-031	Medium	Confluence and Jira run as single nodes; a vulnerability requiring an emergency upgrade means downtime without a maintenance window.	Workplace Technology	2026-12-31
F-2026-032	Medium	The internet-facing Nextcloud proxy has no web application firewall policy.	Workplace Technology	2026-10-31

Id	Severity	Finding	Owner	Due
F-2026-033	Low	14 Nextcloud guest accounts have not logged in for more than 180 days and remain active.	Workplace Technology	2026-08-31

8. Ownership and contacts

Role	Name	Contact
Owner Team lead	Lukas Fjeldstad	lukas.fjeldstad@larkspur-logistics.example
Technical lead (Atlassian)	Nadia El-Amrani	nadia.elamrani@larkspur-logistics.example
Technical lead (Mattermost and Nextcloud)	Owen Pritchard	owen.pritchard@larkspur-logistics.example
SecOps liaison	Priya Nandakumar	secops@larkspur-logistics.example

Workplace Technology owns all four applications and their databases. The ADC publishing policy for the Confluence public space is a joint change with Digital Channels Engineering, which operates the ADC pair.

9. Assessment history

Date	Version	Summary
2024-09-03	1.0	Initial assessment after migration from Atlassian Server to Data Center.
2025-06-18	2.0	Nextcloud and the built-in CODE server added; Mattermost replaces the previous chat tool.
2026-06-12	2.1	Annual review; three findings open.

Appendix A. Service and port matrix

Host	Port	Service	Listens on	Purpose
confluence-01	8090	Confluence (Tomcat)	198.51.100.110	Web application (published via ADC and VPN)
jira-01	8080	Jira (Tomcat)	198.51.100.111	Web application (VPN)
collab-db-01	5432	PostgreSQL	198.51.100.115	Confluence and Jira databases
chat-01	8065	Mattermost	198.51.100.120	Web
files-proxy-01	443	NGINX	203.0.113.40	Nextcloud ingress
files-01	443	Nextcloud (Apache httpd	198.51.100.130	Application and CODE server proxy

Appendix B. Backup, recovery and change management

Backups: the three PostgreSQL instances take nightly dumps to the object store with 35-day retention; the NAS volume holding attachments and files is snapshotted hourly and replicated to the secondary data centre nightly. Confluence and Jira home directories are backed up with the database. A restore of Confluence was exercised on 2026-03-19 (recovery time five hours).

Change management: application upgrades are scheduled through the weekly CAB in the Saturday maintenance window because the Atlassian nodes are single instances. Emergency upgrades follow the emergency change procedure and are announced on the status channel. Nextcloud and its apps are updated monthly from the app store after a test on the staging instance.

Appendix C. Change log

Date	Change	Approved by
2026-02-28	Confluence upgraded to 9.2.21 and Jira to 10.3.18.	CAB
2026-04-18	Mattermost upgraded to 11.8.3; Playbooks enabled for incident response.	CAB
2026-05-16	Nextcloud upgraded to 31.0.6; richdocumentscode updated to 26.4.202.	CAB